

Autonomous Agent Risk Matrix

Scenario: An autonomous AI customer-support agent can read customer messages, retrieve customer records, create support tickets, send emails and issue refunds within a configured limit. It uses an LLM, external APIs, a customer database and conversation history.

Risk	Threat / Scenario	Impact	Control	MAESTRO	NIST
1. Agent Goal Hijack (ASI01)	A malicious instruction in customer-provided content redirects the agent from solving the customer's support problem to retrieving unrelated private customer information.	The agent may pursue an attacker-controlled objective and expose information it was not meant to retrieve.	Keep untrusted content from changing the agent's core task; apply validation and clear agent boundaries.	Data Operations / Agent Frameworks	Map
2. Tool Misuse & Exploitation (ASI02)	The agent has legitimate tools such as customer search, email and refunds, but may use a tool unsafely or supply dangerous arguments.	A legitimate capability could be used to send information, change records or issue an improper refund.	Restrict when each tool can be called, validate tool arguments and check the requested action before execution.	Agent Frameworks	Measure
3. Identity & Privilege Abuse (ASI03)	The support agent has more permissions than its task requires, such as permission to delete customer records when it only needs to handle support tickets.	A compromised or hijacked agent could cause much greater damage because of its excessive authority.	Apply least agency: give the agent only the tools and permissions required for its actual task.	Security & Compliance / Deployment & Infrastructure	Govern
4. Memory & Context Poisoning (ASI06)	Malicious information is stored in conversation history or retrieved context and later influences the agent's decision.	The agent may make unsafe decisions based on poisoned memory or context.	Protect stored memory and retrieved context, validate information before it influences important actions, and monitor abnormal behaviour.	Data Operations	Measure
5. Unexpected Code Execution (ASI05)	The agent is connected to a function or system capable of executing commands, and AI-generated input reaches that function without strong restrictions.	The problem can move from an AI output issue to actual system execution, causing serious system or data impact.	Do not blindly pass AI-generated commands to powerful functions; validate inputs and restrict execution capabilities.	Deployment & Infrastructure / Agent Frameworks	Manage
6. Cascading Failures (ASI08)	The agent calls connected APIs or services, and a failure or unsafe action in one component causes another connected component to behave incorrectly.	One agent failure can spread across connected services and increase the overall impact.	Add limits, validation, monitoring and failure handling between connected components.	Agent Ecosystem	Manage
7. Human-Agent Trust Exploitation (ASI09)	A person trusts the agent because it sounds confident and acts as if its response is correct, even when the information or action is wrong.	People may make incorrect decisions or approve actions based on misleading AI behaviour.	Use clear human oversight for important actions and do not treat confident AI output as proof that an action is safe.	Evaluation & Observability / Security & Compliance	Map